Phase 14: Automated Testing & CI/CD Pipeline

Course Code: 20CYS401 — Secure Software Engineering

Project: Online Book Review and Recommendation Platform

---

1. Automated Test Suite Metrics

A comprehensive Pytest test suite validates all functional, authorization, security, and edge-case behaviors.

Test Execution Summary:

- **Total Tests Executed**: 23

- **Passed**: 23 (100% Pass Rate)

- **Failed**: 0

- **Duration**: ~13.1s

Test Coverage Breakdown:

1. `tests/test_unit_auth.py` (4 tests): Password hashing with bcrypt, minimum password length (≥8 chars), username alphanumeric whitelist, email format validation.

2. `tests/test_unit_validation.py` (3 tests): 1–5 star rating valid boundaries, out-of-range rating rejection, null-byte input stripping.

3. `tests/test_unit_search.py` (3 tests): Title keyword search, genre filtering, SQL injection metacharacter safety (`' OR 1=1 --`).

4. `tests/test_integration_auth.py` (2 tests): Complete user registration lifecycle, login, and logout session invalidation.

5. `tests/test_integration_reviews.py` (1 test): Complete review lifecycle (create, average rating computation, retrieve).

6. `tests/test_authorization.py` (5 tests): User B denied editing User A's review (IDOR), User B denied deleting User A's review, regular user denied `/admin/*` routes (403), administrator granted `/admin/*` routes, anonymous user redirected.

7. `tests/test_fuzzing.py` (4 tests): XSS payload autoescaping in reviews, boundary fuzzing, search input fuzzing, invalid ID handling (404).

8. `tests/test_e2e_workflow.py` (1 test): Complete end-to-end user journey across registration, search, rating, review creation, shelf management, and logout.

---

2. GitHub Actions CI/CD Pipeline

Defined in `.github/workflows/ci.yml`:

- Automated checkout and Python 3.11 setup.

- Automated dependency caching and installation.

- Automated execution of all 23 Pytest tests.

- Static application security testing via Bandit.

- Dockerfile and Kubernetes policy enforcement checks.